



University of Koblenz  
Faculty of Computer Science  
Research Group Software Engineering (RGSE)

---

# TraceSEC: Tracing Security and Privacy in Project Artifacts

Research Report

---

**Research Report — Winter Semester 2025/26**

|                        |                                                   |
|------------------------|---------------------------------------------------|
| <b>Author:</b>         | Manani, Bhavin Jitendrabhai                       |
| <b>Matrikelnummer:</b> | 223201708                                         |
| <b>Supervisors:</b>    | Prof. Dr. Jan Jürjens<br>Marco Ehl<br>Duaa Elsofi |
| <b>Course:</b>         | Research Practical WS2025/2026                    |

## Abstract

Software development artifacts—such as pull request messages, architecture documents, and requirement specifications—encode implicit and explicit signals about the security and quality properties of a system. This report presents the findings of the *TraceSEC* research practical (WS 2025/26) conducted at the University of Koblenz, in which three inter-related empirical studies were carried out to investigate how such signals can be traced, structured, and evaluated against established standards.

**Phase 1** analysed the AIDev dataset of GitHub pull requests to determine how frequently ISO/IEC 25010 quality characteristics appear in agentic versus human pull requests, and whether their presence correlates with acceptance rates. **Phase 2** applied a structured, LLM-assisted prompt pipeline to assess the compliance of the VisiOn EUH2020 project deliverables against four European cybersecurity regulations: the Cyber Resilience Act (CRA), the EU Cybersecurity Act (CSA), the NIS2 Directive, and the Digital Operational Resilience Act (DORA). **Phase 3** mapped privacy requirements of the VisiOn platform to ISO/IEC 25010 quality characteristics, CRA Annex I provisions, and OWASP ASVS controls.

The results show that agentic pull requests reference quality attributes significantly more frequently than human pull requests; that CRA, CSA, and NIS2 are applicable to all seven VisiOn deliverables; and that every privacy requirement analysed can be grounded in at least two independent security standards. These findings collectively demonstrate that systematic trace-link generation between artifacts and quality models is both feasible and informative.

# Contents

|          |                                                          |           |
|----------|----------------------------------------------------------|-----------|
| <b>1</b> | <b>Introduction</b>                                      | <b>4</b>  |
| 1.1      | Problem Statement . . . . .                              | 4         |
| 1.2      | Research Questions . . . . .                             | 4         |
| <b>2</b> | <b>Background</b>                                        | <b>5</b>  |
| 2.1      | ISO/IEC 25010:2023 . . . . .                             | 5         |
| 2.2      | European Cybersecurity Regulations . . . . .             | 5         |
| 2.3      | OWASP ASVS v5.0.0 . . . . .                              | 6         |
| 2.4      | The VisiOn Project . . . . .                             | 6         |
| 2.5      | The AIDev Dataset . . . . .                              | 6         |
| <b>3</b> | <b>Methodology</b>                                       | <b>7</b>  |
| 3.1      | Phase 1: Pull Request Analysis . . . . .                 | 7         |
| 3.1.1    | Dataset and Setup . . . . .                              | 7         |
| 3.1.2    | Keyword Extraction (Task 1.1) . . . . .                  | 7         |
| 3.1.3    | Manual PR Classification (Task 1.2) . . . . .            | 7         |
| 3.2      | Phase 2: Law Compliance Analysis . . . . .               | 8         |
| 3.2.1    | Prompt Meta-Model . . . . .                              | 8         |
| 3.3      | Phase 3: Requirements Mapping . . . . .                  | 10        |
| <b>4</b> | <b>Results</b>                                           | <b>10</b> |
| 4.1      | Phase 1: Pull Request Analysis . . . . .                 | 10        |
| 4.1.1    | RQ1 – Quality Mentions: Agentic vs. Human . . . . .      | 10        |
| 4.1.2    | RQ2 – Co-occurrence of Quality Characteristics . . . . . | 11        |
| 4.1.3    | RQ3 – Human Commentary in Agentic PRs . . . . .          | 12        |
| 4.1.4    | RQ4 – Acceptance Rate Correlation . . . . .              | 13        |
| 4.1.5    | Task 1.2 – Manual PR Classification . . . . .            | 14        |
| 4.2      | Phase 2: Law Compliance Analysis . . . . .               | 15        |
| 4.2.1    | Applicability Matrix . . . . .                           | 15        |
| 4.2.2    | Key Findings per Regulation . . . . .                    | 16        |
| 4.3      | Phase 3: VisiOn Requirements Mapping . . . . .           | 16        |
| <b>5</b> | <b>Discussion</b>                                        | <b>21</b> |
| 5.1      | Phase 1 . . . . .                                        | 21        |
| 5.2      | Phase 2 . . . . .                                        | 21        |
| 5.3      | Phase 3 . . . . .                                        | 22        |
| <b>6</b> | <b>Conclusion</b>                                        | <b>22</b> |

## List of Tables

|    |                                                                                                                                                           |    |
|----|-----------------------------------------------------------------------------------------------------------------------------------------------------------|----|
| 1  | Pull request acceptance rates by quality attribute mention status. . . . .                                                                                | 14 |
| 2  | Manual classification of assigned pull requests (Task 1.2). . . . .                                                                                       | 15 |
| 3  | Applicability matrix: VisiOn deliverables vs. EU cybersecurity laws. YES<br>= applicable, NO = not applicable. . . . .                                    | 16 |
| 4  | Requirement ID 44 – Privacy Verification (Type: PR). <i>Source: VisiOn<br/>Privacy Requirements, Marco Ehl, RGSE Koblenz, 2026.</i> . . . .               | 17 |
| 5  | Requirement ID 45 – Information Usage (Type: PR). <i>Source: VisiOn<br/>Privacy Requirements, Marco Ehl, RGSE Koblenz, 2026.</i> . . . .                  | 17 |
| 6  | Requirement ID 46 – Information Control (Type: PR). <i>Source: VisiOn<br/>Privacy Requirements, Marco Ehl, RGSE Koblenz, 2026.</i> . . . .                | 18 |
| 7  | Requirement ID 47 – Compliance Verification (Type: PR). <i>Source: VisiOn<br/>Privacy Requirements, Marco Ehl, RGSE Koblenz, 2026.</i> . . . .            | 18 |
| 8  | Requirement ID 48 – Visual Compliance Notification (Type: NFR). <i>Source:<br/>VisiOn Privacy Requirements, Marco Ehl, RGSE Koblenz, 2026.</i> . . . .    | 19 |
| 9  | Requirement ID 49 – Integrated Interface for PA Users (Type: NFR). <i>Source:<br/>VisiOn Privacy Requirements, Marco Ehl, RGSE Koblenz, 2026.</i> . . . . | 19 |
| 10 | Requirement ID 50 – Web-Based Interface for Citizens (Type: NFR). <i>Source:<br/>VisiOn Privacy Requirements, Marco Ehl, RGSE Koblenz, 2026.</i> . . . .  | 20 |
| 11 | Requirement ID 51 – PLA Summary for PA Users (Type: NFR). <i>Source:<br/>VisiOn Privacy Requirements, Marco Ehl, RGSE Koblenz, 2026.</i> . . . .          | 20 |

## List of Figures

|   |                                                                                             |    |
|---|---------------------------------------------------------------------------------------------|----|
| 1 | Three-phase methodology pipeline with inputs and outputs. . . . .                           | 7  |
| 2 | Phase 2 five-step compliance analysis process. . . . .                                      | 8  |
| 3 | RQ1: ISO/IEC 25010 quality characteristic mention rates – agentic vs.<br>human PRs. . . . . | 11 |
| 4 | RQ2: Co-occurrence heatmap of ISO/IEC 25010 quality characteristics. . .                    | 12 |
| 5 | RQ3: Quality characteristics mentioned in human review comments on<br>agentic PRs. . . . .  | 13 |
| 6 | Absolute and normalised comparison of agentic vs. human PR mentions. .                      | 13 |
| 7 | RQ4: Comparison of PR acceptance rates with and without ISO/IEC 25010<br>mentions. . . . .  | 14 |

# 1 Introduction

Software projects leave behind a trail of artifacts – commit messages, pull requests, requirement documents, test reports – that carry information about security and quality decisions. The TraceSEC project at the University of Koblenz looks at how these traces can be systematically linked to formal quality standards and legal regulations.

The motivation for this work comes from two trends. First, European digital law has grown rapidly: the Cyber Resilience Act [[European Parliament and Council of the European Union, 2024](#)], the EU Cybersecurity Act [[European Parliament and Council of the European Union, 2019](#)], NIS2 [[European Parliament and Council of the European Union, 2022b](#)], and DORA [[European Parliament and Council of the European Union, 2022a](#)] now require organisations to show compliance at the artifact level, not just declare it. Second, AI coding agents are generating large volumes of pull requests, and it is not yet clear whether their outputs engage with quality concerns the same way humans do.

This practical addressed both issues across three linked phases, described below.

## 1.1 Problem Statement

Software quality and security are hard to track across a project’s lifecycle. Standards like ISO/IEC 25010 and regulations such as the CRA define what properties a system must have, but there is no established, scalable way to check whether actual development artifacts reflect those properties. This study explores how keyword analysis, prompt engineering, and manual mapping can each contribute to closing that gap.

## 1.2 Research Questions

### Phase 1 – Pull Request Analysis:

**RQ1** How often are ISO/IEC 25010 quality characteristics mentioned in agentic vs. human PRs?

**RQ2** Which quality characteristics tend to co-occur in the same PR?

**RQ3** Which characteristics do human reviewers discuss in agentic PRs?

**RQ4** Is there a correlation between quality mentions and PR acceptance?

### Phase 2 – Law Compliance Analysis:

**RQ2.1** How can quality engineering practices be turned into reusable AI prompts for compliance analysis?

**RQ2.2** What prompt structure produces consistent, standards-grounded compliance verdicts?

### Phase 3 – Requirements Mapping:

**RQ3.1** Which ISO/IEC 25010 characteristics are affected by each assigned VisiOn requirement?

**RQ3.2** Which CRA Annex I provisions apply?

**RQ3.3** Which OWASP ASVS v5.0.0 controls are relevant?

## 2 Background

### 2.1 ISO/IEC 25010:2023

ISO/IEC 25010 [ISO/IEC, 2011] is the international standard for software product quality, published by the International Organization for Standardization (ISO) and the International Electrotechnical Commission (IEC). The 2023 edition defines eight top-level quality characteristics: Functional Suitability, Performance Efficiency, Compatibility, Interaction Capability, Reliability, Security, Maintainability, and Flexibility. Each characteristic breaks down into sub-characteristics – for example, Security includes Confidentiality, Integrity, Authenticity, and Non-repudiation. The standard was used in this study as the primary quality model for both keyword extraction (Phase 1) and requirements mapping (Phase 3).

### 2.2 European Cybersecurity Regulations

Four regulations were used in Phase 2:

- **CRA** – Regulation (EU) 2024/2847 [European Parliament and Council of the European Union, 2024]. Covers products with digital elements. Its Annex I, Section 1.3, lists eleven specific cybersecurity requirements (points a–k) covering secure defaults, access control, data protection, vulnerability reporting, and more.
- **CSA** – Regulation (EU) 2019/881 [European Parliament and Council of the European Union, 2019]. Strengthens ENISA and creates a voluntary certification framework for ICT products. Articles 49 and 55 cover certification schemes and documentation obligations.
- **NIS2** – Directive (EU) 2022/2555 [European Parliament and Council of the European Union, 2022b]. Targets critical-sector entities (healthcare, public administration, etc.) with risk management and incident reporting obligations under Articles 21 and 23.
- **DORA** – Regulation (EU) 2022/2554 [European Parliament and Council of the European Union, 2022a]. Applies exclusively to financial-sector entities. Included to test whether the prompt pipeline can correctly identify non-applicability.

One important note: the CRA (2024), NIS2 (2023), and DORA (2025) all post-date the

VisiOn project (2015–2017). The Phase 2 analysis is therefore a *retrospective* exercise – it asks whether VisiOn would comply if built today, not whether it was legally required to at the time.

## 2.3 OWASP ASVS v5.0.0

The Application Security Verification Standard [OWASP Foundation, 2024] is published by the OWASP Foundation, a non-profit focused on software security. ASVS v5.0.0 provides a catalogue of technically actionable verification controls identified by chapter and control number (e.g., V14.1.1). It was used in Phase 3 to complement the higher-level obligations of the CRA with concrete, implementation-level requirements.

## 2.4 The VisiOn Project

VisiOn (*Visual Privacy Management in User-Centric Open Environments*) was an EU Horizon 2020 project (Grant No.653642), coordinated by Prof.Dr. Jan Jürjens at the University of Koblenz [VisiOn Consortium, 2014]. It ran from July 2015 to June 2017 and produced the VisiOn Privacy Platform (VPP), a tool to help citizens and public administrations manage privacy policies. Pilots were run with a paediatric hospital, a PA office, and the Italian Ministry of Economic Development. Seven project deliverables (D1–D7) covering requirements, pilots, testing, training, and dissemination were used as the analysis corpus.

## 2.5 The AIDev Dataset

The AIDev dataset [SAIL Research, 2026a] is a collection of GitHub pull requests available via Hugging Face, assembled to support research on AI-assisted development. It contains 939,409 PRs: 932,791 generated by LLM-based coding agents and 6,618 written by humans. The approximately 141:1 imbalance between agentic and human PRs is a key consideration for interpreting the Phase 1 results.

### 3 Methodology

Figure 1 shows the overall three-phase pipeline.

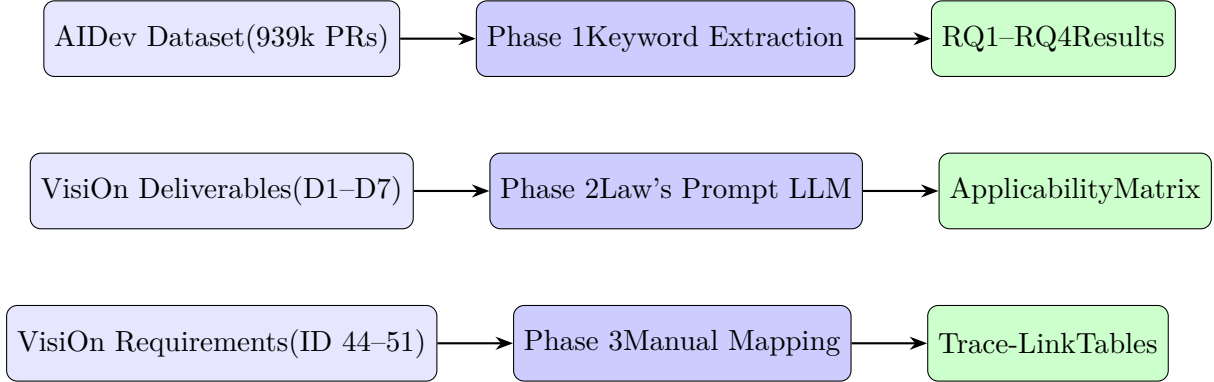


Figure 1: Three-phase methodology pipeline with inputs and outputs.

#### 3.1 Phase 1: Pull Request Analysis

##### 3.1.1 Dataset and Setup

The AIDev dataset was accessed via the Hugging Face Datasets library using a Google Colaboratory notebook provided by the supervisors [SAIL Research, 2026b]. Data was loaded into a pandas `DataFrame`. For each PR, the `title`, `body`, `comments`, and `merged` fields were extracted.

##### 3.1.2 Keyword Extraction (Task 1.1)

A keyword lexicon was built by mapping ISO/IEC 25010:2023 sub-characteristic names and their common synonyms to each top-level characteristic. For example, terms like *encrypt*, *authentication*, *confidential* map to Security, and terms like *modular*, *refactor*, *maintainable* map to Maintainability. Using Python’s `re` module, each PR body was scanned case-insensitively. A PR was counted as mentioning a characteristic if at least one of its keywords appeared. All counts were normalised per PR to account for the large dataset imbalance. The approach follows keyword-based quality detection methods used in prior work [Guo et al., 2017].

For RQ3, the same matching was applied to the `comments` field only, to isolate what human reviewers focused on when reviewing agentic PRs.

##### 3.1.3 Manual PR Classification (Task 1.2)

Eight pull requests were manually classified using the provided spreadsheet (`task1_2_classification_study.xlsx`). For each PR, the ISO/IEC 25010 characteristic that was

*increased* and the one *decreased* were identified, supported by a direct quote from the PR text.

### 3.2 Phase 2: Law Compliance Analysis

Figure 2 shows the five-step process used to assess each VisiOn deliverable against each regulation.

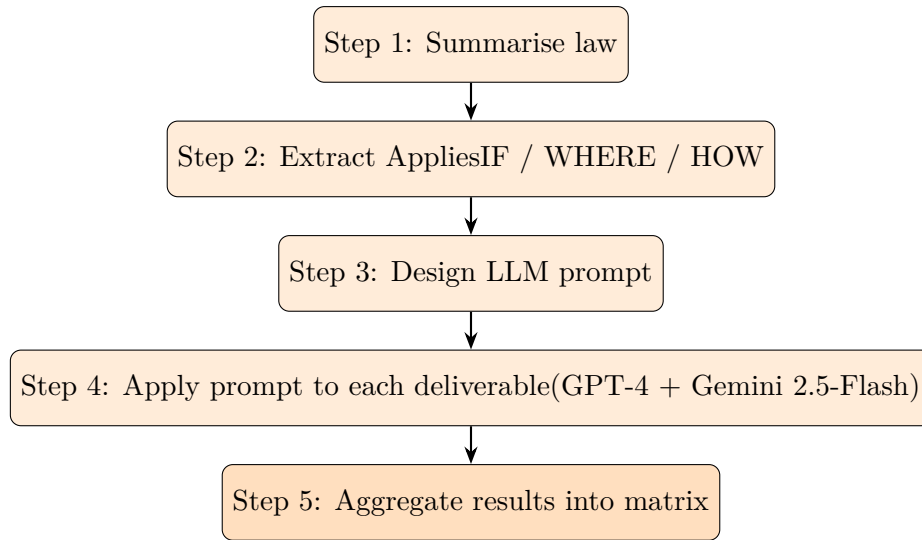


Figure 2: Phase 2 five-step compliance analysis process.

#### 3.2.1 Prompt Meta-Model

Each prompt followed a three-part structure that was the same for all four regulations:

1. **AppliesIF** – Does this regulation apply? Answer YES if confidence  $\geq 70\%$ , based on project context (EU funding, stakeholder type, network-connected components).
2. **AppliesWHERE** – Which components, modules, or SDLC phases does it affect?
3. **ImplementationHOW** – What specific actions are needed, citing the relevant article or annex point?

The LLM was instructed to return structured JSON. Two models were used (GPT-4 and Gemini 2.5-Flash) to cross-check results. Where they disagreed, the deliverable text was reviewed manually to resolve the verdict.

Below is a condensed example of the prompt used for CRA and the output for Deliverable D7:

Listing 1: CRA prompt structure (condensed).

```

You are a legal and technical compliance analyst specializing in
EU cybersecurity law and software quality engineering.
  
```

Analyze the following project deliverable in relation to the Cyber Resilience Act (CRA, Regulation (EU) 2024/2847, Annex I, Section 1.3 a-k).

Focus on:

- ISO/IEC 25010 quality characteristics: Security (Confidentiality, Integrity, Authenticity), Reliability, and Maintainability.
- SDLC phases: Development, Testing, Deployment, Maintenance.
- Artifacts: source code, architecture documentation, security requirements, test reports, deployment configurations.
- Activities: secure implementation, security testing, vulnerability management, patch and update processes.

Decision Rule for Applies\_IF:

- Return "YES" if there is a 70% or higher likelihood that the deliverable describes a hardware or software product with a direct or indirect logical or physical data connection to a device or network placed or intended for the EU market (Art. 3(1)). Partial evidence such as mentions of platforms, web services, APIs, user authentication, data transmission, or network-connected components is sufficient to reach the 70% threshold.
- Return "NO" only if there is clear evidence that the product has no network connectivity or is explicitly outside the EU market scope.
- Do NOT return UNCLEAR. Make a definitive decision based on all available evidence and reasonable inference.

Listing 2: Abbreviated GPT-4 output for D7 (Privacy Requirements).

```
{
  "AppliesIF": "YES",  "Confidence": 0.92,
  "Justification": "D7 describes a network-connected privacy
    platform (VPP) processing personal data of citizens and PAs.
    This constitutes a product with digital elements under CRA.",
  "AppliesWHERE": ["VPP", "Citizen Auth Server", "DAE"],
  "ImplementationHOW": {
    "1.3(b)": "Enforce authentication on all interfaces.",
    "1.3(c)": "Encrypt personal data at rest and in transit.",
    "1.3(j)": "Implement audit logging for all data access."
  }
}
```

```

    }
}

```

### 3.3 Phase 3: Requirements Mapping

Eight VisiOn privacy requirements (IDs 44–51) from the requirements document compiled by Marco Ehl (RGSE, University of Koblenz, 2026) [[VisiOn Consortium, 2016](#)] were assigned to this student. For each requirement, three mappings were done manually:

**Task 1** Map to ISO/IEC 25010:2023 quality characteristics, citing the relevant section of the standard.

**Task 2** Map to CRA Annex I, Section 1.3, points (a)–(k).

**Task 3** Map to OWASP ASVS v5.0.0 controls, citing the control ID.

Each mapping entry is accompanied by a justification explaining why the selected standard element applies to the requirement, and an importance statement describing the resulting security or quality impact. The mappings were produced through manual reasoning grounded directly in the formal standard texts. To reduce individual oversight errors, the results were cross-verified using multiple AI language models, with any conflicting interpretations resolved by returning to the original standard text.

## 4 Results

### 4.1 Phase 1: Pull Request Analysis

The results of the Phase 1 empirical analysis of the AIDev dataset (40,214 total pull requests) reveal distinct patterns in how software quality is discussed by AI agents compared to human developers.

#### 4.1.1 RQ1 – Quality Mentions: Agentic vs. Human

The keyword-based extraction identified a significant disparity in quality attribute discourse between the two groups. Agentic pull requests (PRs) mentioned quality characteristics much more frequently than human PRs across all eight top-level ISO/IEC 25010 categories. The four most frequent attributes in the agentic subset were:

1. User Assistance (sub-characteristic of Interaction Capability)
2. Compatibility
3. Security
4. Maintainability

While human developers focused primarily on Security and Reliability, their mention frequencies remained substantially lower than those of AI agents. This suggests that AI agents generate more verbose, structured descriptions that explicitly label the properties they intend to improve, whereas humans may rely on external context.

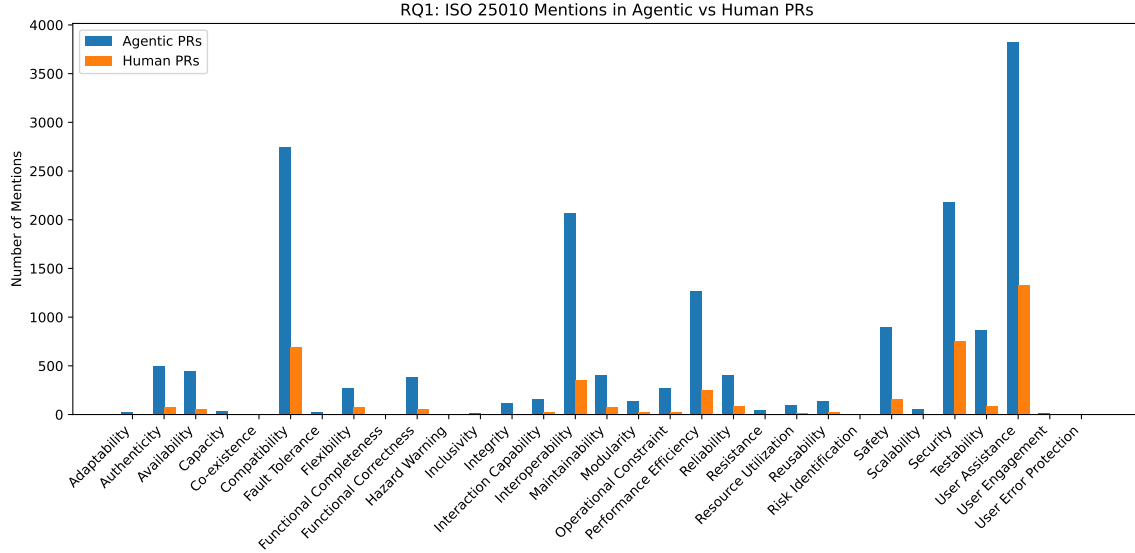


Figure 3: RQ1: ISO/IEC 25010 quality characteristic mention rates – agentic vs. human PRs.

#### 4.1.2 RQ2 – Co-occurrence of Quality Characteristics

Analysis of PRs containing multiple attributes revealed three dominant co-occurrence patterns:

- **Compatibility – Interoperability:** Changes enabling information exchange inherently affect both dimensions.
- **Security – Testability:** Security-related PRs often include verification steps or test suites.
- **Reliability – Maintainability:** Improvements in fault tolerance often reference modularity and analysability.

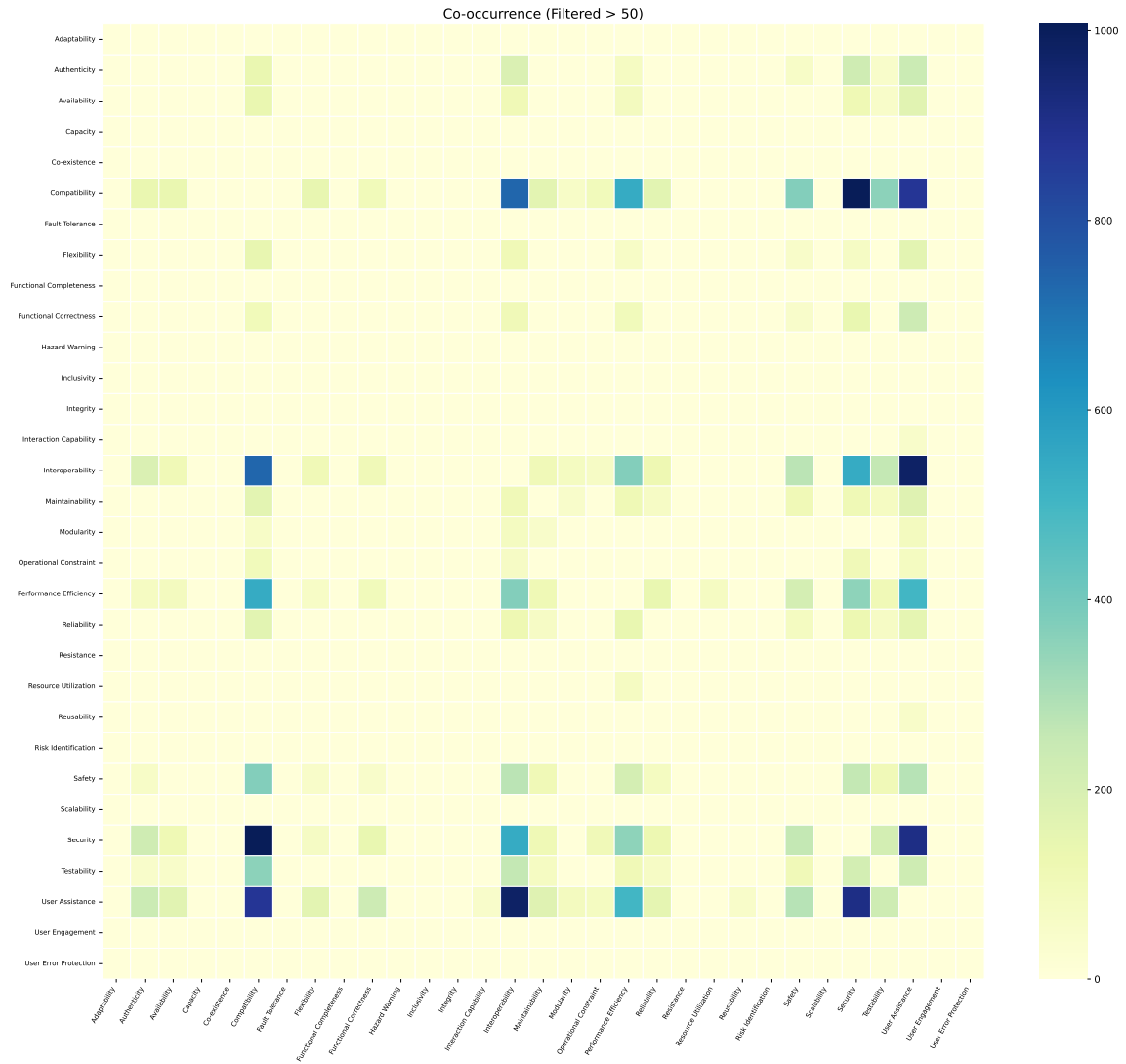


Figure 4: RQ2: Co-occurrence heatmap of ISO/IEC 25010 quality characteristics.

#### 4.1.3 RQ3 – Human Commentary in Agentic PRs

When reviewing PRs authored by AI agents, human developers focused their feedback on four specific areas: User Assistance, Security, Testability, and Compatibility. This indicates that human reviewers act as a quality validation layer, scrutinising user-facing and critical system dimensions rather than structural properties like modularity.

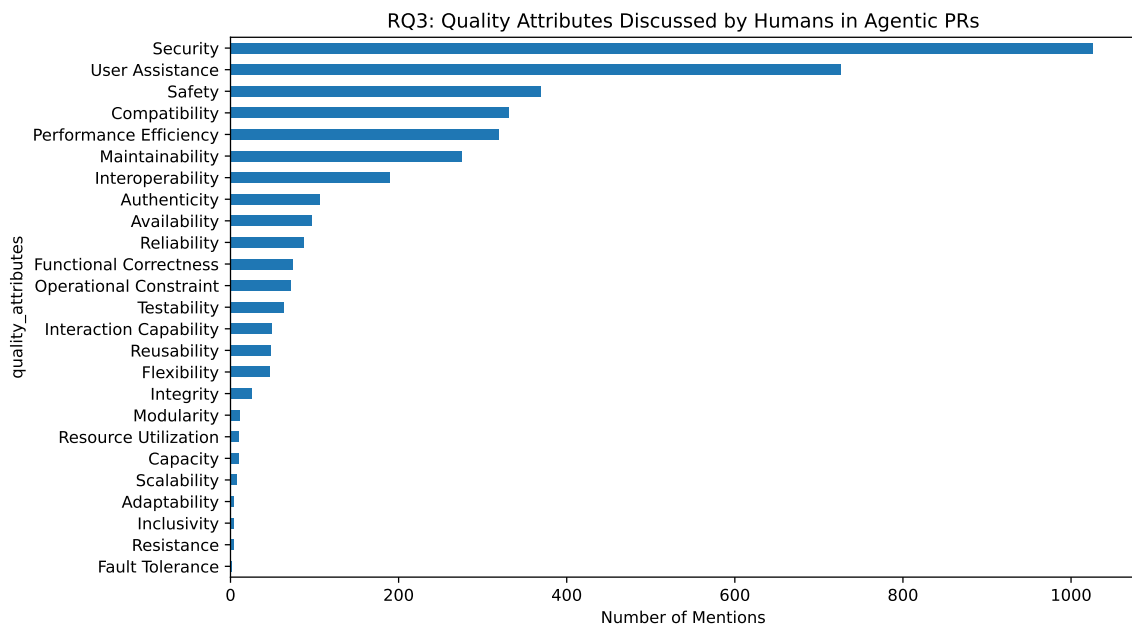


Figure 5: RQ3: Quality characteristics mentioned in human review comments on agentic PRs.

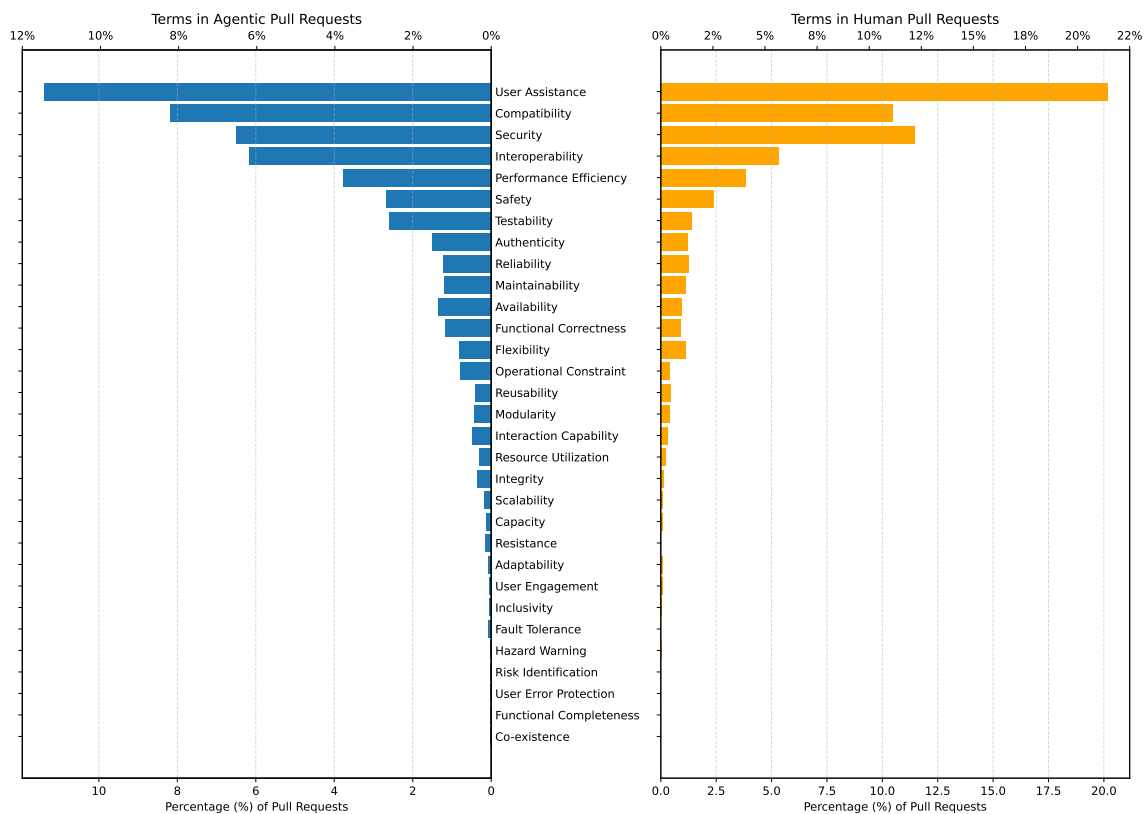


Figure 6: Absolute and normalised comparison of agentic vs. human PR mentions.

#### 4.1.4 RQ4 – Acceptance Rate Correlation

The data showed a counter-intuitive relationship between quality discourse and PR success:

Table 1: Pull request acceptance rates by quality attribute mention status.

| Group                                         | Acceptance Rate |
|-----------------------------------------------|-----------------|
| PRs mentioning ISO/IEC 25010 terms            | 59.2%           |
| PRs <i>not</i> mentioning ISO/IEC 25010 terms | 78.0%           |

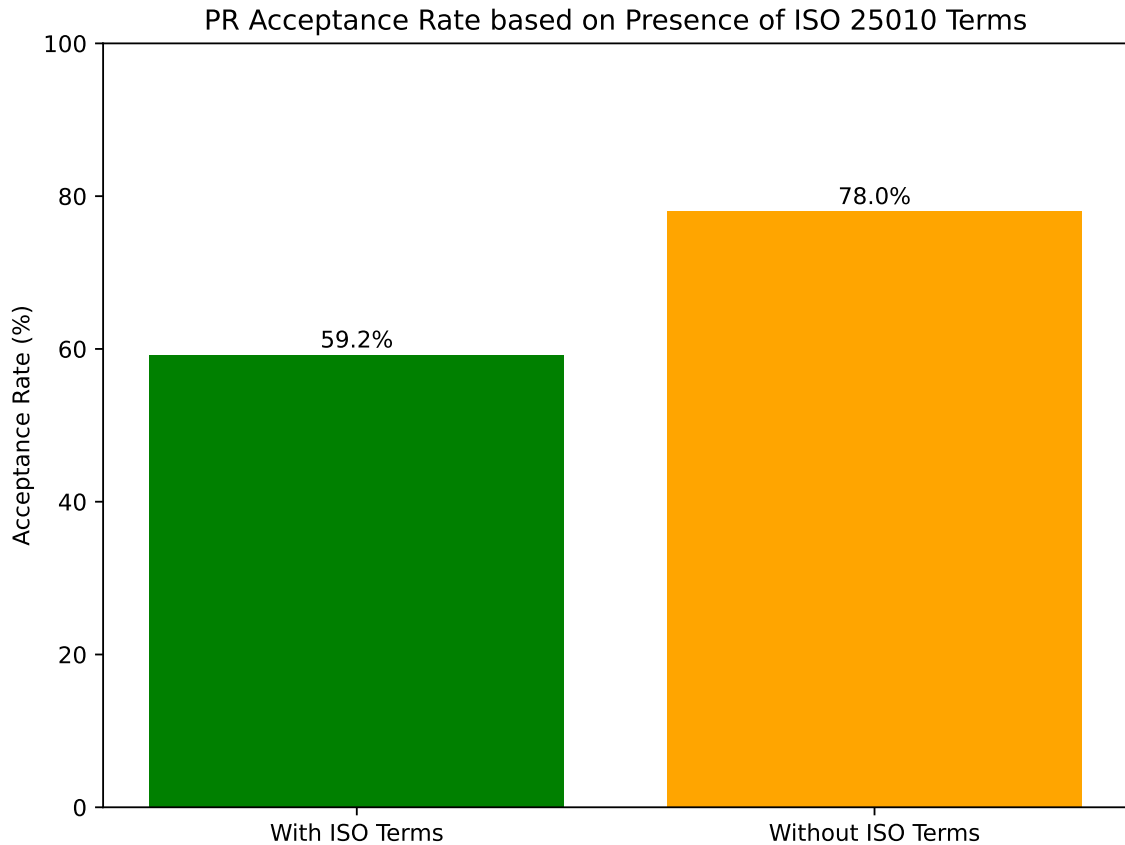


Figure 7: RQ4: Comparison of PR acceptance rates with and without ISO/IEC 25010 mentions.

This lower acceptance rate for quality-rich PRs likely stems from the fact that agentic PRs proposing large, multi-faceted changes are subject to higher scrutiny and longer review cycles than brief, narrowly scoped human fixes. Aggregating all PRs: those mentioning quality terms have a lower merge rate (59%) than those that do not (78%). This is counter-intuitive and discussed in Section 5.

#### 4.1.5 Task 1.2 – Manual PR Classification

Table 2 shows the manual ISO/IEC 25010 classification for the eight assigned pull requests.

Table 2: Manual classification of assigned pull requests (Task 1.2).

| PR ID      | Increased                                          | Decreased                                      | Supporting Quote                                                         |
|------------|----------------------------------------------------|------------------------------------------------|--------------------------------------------------------------------------|
| 3152800383 | Maintainability<br>/ Self-<br>Descriptiveness      | Functional Suit-<br>ability / Cor-<br>rectness | <i>“comprehensive package<br/>summary”</i>                               |
| 3190392108 | Maintainability<br>/ Modularity                    | Compatibility<br>/ Interoperabil-<br>ity       | <i>“upgrades TypeSpec Azure<br/>dependencies to 0.57.1”</i>              |
| 3103637450 | Functional Suit-<br>ability / Com-<br>pleteness    | Reliability /<br>Fault Tolerance               | <i>“allows users to import<br/>IConfiguration directly”</i>              |
| 3176572345 | Functional Suit-<br>ability / Cor-<br>rectness     | Reliability /<br>Fault Tolerance               | <i>“Real-time conflict detec-<br/>tion”</i>                              |
| 3199946355 | Reliability /<br>Fault Tolerance                   | Reliability /<br>Fault Tolerance               | <i>“fixes a critical runtime<br/>panic”</i>                              |
| 3242573593 | Security / In-<br>tegrity                          | Compatibility<br>/ Interoperabil-<br>ity       | <i>“Lock markdown-pdf to ver-<br/>sion 1.5”</i>                          |
| 3239733181 | Functional Suit-<br>ability / Appro-<br>priateness | Reliability /<br>Fault Tolerance               | <i>“Improve responsiveness of<br/>message display”</i>                   |
| 3222408174 | Functional Suit-<br>ability / Com-<br>pleteness    | Maintainability<br>/ Analysability             | <i>“Updated UI components to<br/>include artifact mode tog-<br/>gle”</i> |

## 4.2 Phase 2: Law Compliance Analysis

### 4.2.1 Applicability Matrix

Table 3 summarises the final verdicts across all seven deliverables and four regulations.

Table 3: Applicability matrix: VisiOn deliverables vs. EU cybersecurity laws. YES = applicable, NO = not applicable.

| Deliverable                             | CRA | CSA | NIS2 | DORA |
|-----------------------------------------|-----|-----|------|------|
| D1 – Training Activities Manual         | YES | YES | YES  | NO   |
| D2 – VisiOn Pilots Reports              | YES | YES | YES  | NO   |
| D3 – VisiOn Pilots Preparation          | YES | YES | YES  | NO   |
| D4 – Scenarios for the Pilots           | YES | YES | YES  | NO   |
| D5 – VPP Testing Results                | YES | YES | YES  | NO   |
| D6 – Dissemination & Standardisation    | YES | YES | YES  | NO   |
| D7 – Citizens & PA Privacy Requirements | YES | YES | YES  | NO   |

#### 4.2.2 Key Findings per Regulation

**CRA (Regulation (EU) 2024/2847):** All deliverables are in scope because VisiOn builds a network-connected privacy platform (VPP) that processes personal data. The main compliance gaps identified are: no explicit SBOM, no documented secure-by-default configuration, and no defined vulnerability reporting process to ENISA within 24 hours (Annex I, points 1.3(a), 1.3(c), and Art. 14).

**CSA (Regulation (EU) 2019/881):** Applicable because the VPP and related ICT tools could be submitted for ENISA certification. Key gap: no user-facing security documentation as required by Art. 55(1), and no declared security support timeline (Art. 55(3)).

**NIS2 (Directive (EU) 2022/2555):** Applicable because the pilot partners include a paediatric hospital and public administrations – both critical-sector entities under NIS2 Annexes I and II. Gaps: no formal risk management framework (Art. 21(1)), no incident reporting procedures (Art. 23), and no evidence of cyber-hygiene training (Art. 21(2)(g)).

**DORA (Regulation (EU) 2022/2554):** Not applicable. DORA covers only financial entities. VisiOn’s stakeholders are in healthcare and public administration. Both GPT-4 and Gemini returned NO with  $\geq 92\%$  confidence. This consistent result validates that the prompt pipeline does not over-attribute applicability.

### 4.3 Phase 3: VisiOn Requirements Mapping

The full three-task mapping for requirements ID 44–51 is presented in Tables 4–11.

Table 4: Requirement ID 44 – Privacy Verification (Type: PR). *Source: VisiOn Privacy Requirements, Marco Ehl, RGSE Koblenz, 2026.*

| Field         | Content                                                                                                                                                                                                                                 |
|---------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description   | The VisiOn platform shall enable the PA user to notify the citizen if further information is needed to verify privacy requirements.                                                                                                     |
| ISO/IEC 25010 | <b>User Assistance</b> (§3.4.7) and <b>Self-Descriptiveness</b> (§3.4.8). The notification guides the citizen on what is missing, which is user assistance; how clearly that notification is presented relates to self-descriptiveness. |
| CRA Annex I   | <b>Point 1.3(j)</b> – provide security-related information. Notifying users when data is needed for verification directly fulfils this transparency obligation.                                                                         |
| OWASP ASVS    | <b>V14.1.1</b> (document data protection requirements) and <b>V14.2.4</b> (verify implementation matches documented privacy controls).                                                                                                  |

Table 5: Requirement ID 45 – Information Usage (Type: PR). *Source: VisiOn Privacy Requirements, Marco Ehl, RGSE Koblenz, 2026.*

| Field         | Content                                                                                                                                                                            |
|---------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description   | The VisiOn platform shall analyse the infrastructure of the socio-technical system whenever external actors are involved.                                                          |
| ISO/IEC 25010 | <b>Functional Completeness</b> (§3.1.1) and <b>Interoperability</b> (§3.3.2). All external actors must be covered (completeness); interaction with them requires interoperability. |
| CRA Annex I   | <b>Point 1.3(h)</b> – limit attack surfaces from external interfaces. Analysing the infrastructure for external actors is exactly what this point requires.                        |
| OWASP ASVS    | <b>V13.1.1</b> (document all external communications) and <b>V13.2.4</b> (verify external actors are enumerated).                                                                  |

Table 6: Requirement ID 46 – Information Control (Type: PR). *Source: VisiOn Privacy Requirements, Marco Ehl, RGSE Koblenz, 2026.*

| Field         | Content                                                                                                                                                                                      |
|---------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description   | The platform shall capture obligations derived by applicable law governing personal information transmission.                                                                                |
| ISO/IEC 25010 | <b>Functional Completeness</b> (§3.1.1) and <b>Functional Appropriateness</b> (§3.1.3). Every legal obligation must be captured (completeness) and then applied correctly (appropriateness). |
| CRA Annex I   | <b>Points 1.3(d) and 1.3(j).</b> Obligations must be accurate and protected from modification (d); monitoring how they are applied provides accountability (j).                              |
| OWASP ASVS    | <b>V14.1.1</b> – data protection levels must account for applicable privacy regulations.                                                                                                     |

Table 7: Requirement ID 47 – Compliance Verification (Type: PR). *Source: VisiOn Privacy Requirements, Marco Ehl, RGSE Koblenz, 2026.*

| Field         | Content                                                                                                                                                             |
|---------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description   | The platform shall analyse whether information transmission complies with governing laws.                                                                           |
| ISO/IEC 25010 | <b>Functional Correctness</b> (§3.1.2). The platform must produce an accurate compliance verdict – this is precisely the definition of correctness in the standard. |
| CRA Annex I   | <b>Points 1.3(c) and 1.3(d).</b> Checking transmission compliance requires protecting confidentiality and integrity of data in transit.                             |
| OWASP ASVS    | <b>V14.2.4</b> – verify that the implementation of data transmission matches documented privacy rules.                                                              |

Table 8: Requirement ID48 – Visual Compliance Notification (Type: NFR). *Source: VisiOn Privacy Requirements, Marco Ehl, RGSE Koblenz, 2026.*

| Field         | Content                                                                                                                                                                                                                                                       |
|---------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description   | The VisiOn platform shall visually notify the PA user if information transmission meets/does not meet the privacy requirements specified by the citizen, and if information transmission meets/does not meet the laws governing the information transmission. |
| ISO/IEC 25010 | <b>Self-Descriptiveness</b> (§3.4.8) and <b>Appropriateness Recognizability</b> (§3.4.1). Visual alerts must allow users to immediately determine compliance status without additional steps.                                                                 |
| CRA Annex I   | <b>Point 1.3(j)</b> . Visual notifications are a form of security-related information delivery, enabling the PA user to stop an unlawful transfer in real time.                                                                                               |
| OWASP ASVS    | <b>V16.5.1</b> (return appropriate messages when access control fails) and <b>V16.3.2</b> (ensure notifications do not leak internal configuration).                                                                                                          |

Table 9: Requirement ID49 – Integrated Interface for PA Users (Type: NFR). *Source: VisiOn Privacy Requirements, Marco Ehl, RGSE Koblenz, 2026.*

| Field         | Content                                                                                                                                                            |
|---------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description   | The platform shall provide PA users with an integrated interface for all their activities.                                                                         |
| ISO/IEC 25010 | <b>Operability</b> (§3.4.3) and <b>Appropriateness Recognizability</b> (§3.4.1). A single interface reduces navigation effort and must clearly signal its purpose. |
| CRA Annex I   | <b>Points 1.3(b) and 1.3(h)</b> . A centralised interface creates a single access control boundary (b) and reduces the overall attack surface (h).                 |
| OWASP ASVS    | <b>V8.4.2</b> – administrative interfaces require multiple security layers; a compromised PA interface could expose all citizen data.                              |

Table 10: Requirement ID 50 – Web-Based Interface for Citizens (Type: NFR). *Source: VisiOn Privacy Requirements, Marco Ehl, RGSE Koblenz, 2026.*

| Field         | Content                                                                                                                                                  |
|---------------|----------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description   | The platform shall provide citizen users with a web-based interface for all their activities.                                                            |
| ISO/IEC 25010 | <b>Operability</b> (§3.4.3) and <b>Adaptability</b> (§3.8.1). A web interface works across devices (adaptability) and must be easy to use (operability). |
| CRA Annex I   | <b>Point 1.3(h).</b> A public-facing web interface expands the attack surface; minimising it is mandatory under this point.                              |
| OWASP ASVS    | <b>V3.1.1</b> – document required browser security features (HTTPS, HSTS, CSP). Without these, citizen data in transit is at risk.                       |

Table 11: Requirement ID 51 – PLA Summary for PA Users (Type: NFR). *Source: VisiOn Privacy Requirements, Marco Ehl, RGSE Koblenz, 2026.*

| Field         | Content                                                                                                                                                                            |
|---------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description   | The VisiOn platform shall represent the PLA concerning the citizen information to PA users as a summary of the allowed/forbidden activities to be performed over such information. |
| ISO/IEC 25010 | <b>Self-Descriptiveness</b> (§3.4.8). Translating a complex legal agreement into a simple allowed/forbidden list is exactly what self-descriptiveness means in practice.           |
| CRA Annex I   | <b>Points 1.3(b) and 1.3(j).</b> The PLA defines the access control boundary (b); the system must monitor activity against it and alert when forbidden actions are attempted (j).  |
| OWASP ASVS    | <b>V8.1.1</b> – the PLA is an authorisation policy; V8.1.1 ensures it is translated into verifiable, implementable access controls.                                                |

## 5 Discussion

### 5.1 Phase 1

**The “testing” problem.** The keyword “testing” appearing in 94.9% of agentic PRs is the most important result to question. The word is common in English and shows up in PR bodies for reasons completely unrelated to quality consciousness (e.g., “I tested this on my machine”). Under ISO/IEC 25010:2023, *Testability* is a sub-characteristic of Maintainability – not a standalone quality dimension. The dominance of this one term skews the overall picture considerably. A future study should use narrower terms (“unit test coverage,” “test suite”) or an LLM-based classifier to reduce this noise.

**Dataset imbalance.** The 141:1 ratio of agentic to human PRs means all human-side observations come from just 6,618 records. This is small enough to be unreliable for fine-grained comparisons. The results for human PR behaviour should be treated as exploratory rather than conclusive.

**Lower acceptance rate for quality-mentioning PRs.** PRs that mention ISO/IEC 25010 terms have a merge rate of 59% versus 78% for those that do not. The most likely explanation is that quality-rich descriptions tend to come from agents proposing larger, more complex changes, which face more scrutiny. It is not that mentioning quality terms *hurts* a PR’s chances – it is simply that the kind of PRs that mention them are harder to review and merge. Controlling for PR size (lines changed) would be the right next step.

**What is missed without manual review.** The comment analysis for RQ3 found that under 2% of agentic PRs received a quality-keyword comment from a human reviewer. This does not mean reviewers ignored quality in the other 98% of cases – they just used different words (“looks good,” “LGTM,” “can you add a test?”). Keyword matching at the comment level misses most of the actual quality discourse. A manual inspection of a sample of reviewed PRs would have provided a more accurate picture of what reviewers actually care about.

### 5.2 Phase 2

**Temporal gap.** CRA, NIS2, and DORA did not exist when VisiOn was built. The compliance analysis answers a hypothetical – what would need to change if VisiOn were built today. This is useful for learning purposes but does not reflect a real compliance obligation.

**LLM verdict reliability.** The 70% confidence threshold is a design choice. Setting it lower would produce more YES results; higher would produce more NO results or

ambiguity. The DORA NO result is the most trustworthy verdict in the matrix, because it rests on a hard, objectively verifiable exclusion (sector scope), not on probabilistic inference about document content. The YES results for CRA, CSA, and NIS2 are well-reasoned but no independent legal expert validated them. The *ImplementationHOW* outputs are largely derived from the regulation text itself, not from specific evidence in the deliverables. Distinguishing between “this deliverable contains evidence for this obligation” and “this obligation exists and must be implemented” would make the analysis more precise.

**What “applying a law” means.** Several presentation reviewers asked what it actually means to say a law “applies” to a 2015 document. In this study, applicability means: *if this project were subject to this regulation, the deliverable would be in scope*. It does not mean the document currently satisfies the regulation – in most cases, it does not.

### 5.3 Phase 3

**Scope.** Eight requirements out of 92 were analysed. No claims are made about the remaining 84. Within the eight, the mapping is complete and cross-verified.

**Recurring patterns.** Six of the eight requirements map to Interaction Capability characteristics (self-descriptiveness, operability, user assistance). This makes sense given VisiOn’s focus on user-facing privacy management. CRA point 1.3(j) (provide security-related information) appears in five of eight mappings, suggesting that transparency and notification are the dominant compliance theme for this requirement type.

**Validity.** The mappings were done by a single analyst. There was no second annotator to check agreement. The cross-verification using AI tools caught some inconsistencies, but this is not a substitute for proper inter-rater reliability testing. The results should be read as a well-reasoned proposal, not a validated ground truth.

## 6 Conclusion

This report described three phases of empirical work within the TraceSEC research practical.

Phase 1 showed that AI coding agents produce PR descriptions that mention ISO/IEC 25010 quality terms far more often than humans do, but this difference is partly an artefact of agent verbosity and broad keyword definitions. The counter-intuitive finding that quality-mentioning PRs have lower acceptance rates is best explained by PR scope rather than quality awareness actually hurting acceptance chances.

Phase 2 showed that the VisiOn project deliverables would fall under CRA, CSA, and NIS2 if produced today, while DORA consistently does not apply. The three-part prompt

structure (AppliesIF / AppliesWHERE / ImplementationHOW) proved reusable across all four regulations and can serve as a template for future compliance analysis work.

Phase 3 showed that every analysed VisiOn privacy requirement maps to at least two independent standards, and that Interaction Capability characteristics and CRA 1.3(j) are the most common across the requirement set. The multi-standard mapping approach is practical and reproducible with the right standard documents.

The main lesson across all three phases is that automated methods (keyword extraction, LLM prompts) scale well but need human oversight to be reliable. Manual annotation is slow but produces results that can actually be defended. Combining both – using automation for triage and human review for validation – is the most realistic path toward practical compliance traceability.

## References

- European Parliament and Council of the European Union. Regulation (EU) 2019/881 of the European Parliament and of the Council on ENISA (the European Union agency for cybersecurity) and on information and communications technology cybersecurity certification (EU Cybersecurity Act). Official Journal of the European Union, OJ L 151, 2019. <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=LEGISSUM:4398780>.
- European Parliament and Council of the European Union. Regulation (EU) 2022/2554 of the European Parliament and of the Council on digital operational resilience for the financial sector (DORA). Official Journal of the European Union, OJ L 333, 2022a. <https://eur-lex.europa.eu/eli/reg/2022/2554/oj/eng>.
- European Parliament and Council of the European Union. Directive (EU) 2022/2555 of the European Parliament and of the Council on measures for a high common level of cybersecurity across the Union (NIS2 Directive). Official Journal of the European Union, OJ L 333, 2022b. <https://eur-lex.europa.eu/eli/dir/2022/2555/oj/eng>.
- European Parliament and Council of the European Union. Regulation (EU) 2024/2847 of the European Parliament and of the Council on horizontal cybersecurity requirements for products with digital elements (Cyber Resilience Act). Official Journal of the European Union, OJ L 2024/2847, 2024. <https://eur-lex.europa.eu/eli/reg/2024/2847/oj/eng>.
- Jin Guo, Jinghui Cheng, and Jane Cleland-Huang. Semantically enhanced software traceability using deep learning techniques. In *Proceedings of the 39th International Conference on Software Engineering (ICSE)*, pages 3–14. IEEE Press, 2017. doi: 10.1109/ICSE.2017.8.
- ISO/IEC. Systems and software engineering — Systems and software Quality Requirements and Evaluation (SQuaRE) — Product quality, ISO/IEC 25010:2011, 2011. Second edition ISO/IEC 25010:2023 also referenced.
- OWASP Foundation. OWASP Application Security Verification Standard 5.0.0. OWASP, <https://owasp.org/www-project-application-security-verification-standard/>, 2024.
- SAIL Research. AIDev: A dataset of AI-authored GitHub pull requests. MSR 2026 Mining Challenge, <https://2026.msrfconf.org/track/msr-2026-mining-challenge>, 2026a.
- SAIL Research. Example notebook for loading the AIDev dataset. Google Colaboratory,

<https://colab.research.google.com/github/SAILResearch/AITeammatesinSE3/blob/main/analysis/loadAIDev.ipynb>, 2026b.

VisiOn Consortium. VisiOn: Visual privacy management in user-centric open environments. EU Horizon 2020 Project, Grant No. 653642, CORDIS <https://cordis.europa.eu/project/id/653642>, 2014.

VisiOn Consortium. Citizens and public administrations privacy requirements. VisiOn Project Deliverable D7, University of Koblenz TraceSEC Materials, 2016.